GitHub AI Radar — 2026-10-25

本期按北京时间 2026-10-25 归档，核对 GitHub Trending（日榜）、官方 GitHub REST 元数据、Release/README，并与既有 79 个项目、10 月 24 日日报、历史快照和 trends/ 对比。确认 3 个已跟踪项目的重要升级/二次热度信号 + 2 个首次纳入项目，满足“ 有实质变化才发布 ”的门槛。

> 数据口径： Star/Fork 为 2026-10-24 23:55 – 23:59 UTC 左右 GitHub REST 瞬时值；不等于自然日新增。GitHub Trending 的“ stars today ”是滚动榜单显示值，不是 REST 历史快照差。官方 Release 日期按 UTC；技术效果、安全性和性能未独立复现。

核心判断

Agent 安全从“ 有没有沙箱 ”转向“ 权限能否在运行时执行、审计、撤销和跨任务继承 ”；控制面从“ 可调度多个 Agent ”走向“ 任务私密性、人工可用性与故障恢复的明确契约 ”。 OpenShell、Anthropic Sandbox Runtime 与 Paperclip 从不同层面收紧执行/授权边界；OpenRig 补足人在环路中的离线、唤醒与部分恢复语义；Cindy 展示消费级跨 Harness 工作台的热度，但开源客户端与非开源后端必须区分。

1. NVIDIA OpenShell v0.1.5：可移植 Sandbox Protocol + 可观测策略执行

- 官方仓库： https://github.com/NVIDIA/OpenShell ；Release： https://github.com/NVIDIA/OpenShell/releases/tag/v0.1.5 ， 2026-10-20 17:28 UTC。GitHub REST 19,468 Stars / 1,930 Forks， Apache-2.0。既有 2026-09-29 快照为 9,397 Stars；两次观测相差 10,071，跨度近四周，不能当成日增量。本次 GitHub Trending 日榜观察到 893 stars today（页面滚动口径）。
- v0.1.5 发布版本化 Sandbox Protocol，允许第三方实现隔离后端；新增可选 config_delivery_mode="push"，官方称策略配置下发约 100 ms（轮询仍为默认、此前可达约 10 秒），不是独立测量。
- 审计与身份边界：OCSF 事件可作为 OTLP 日志导出，认证拒绝也记录原因与 request ID；Kubernetes Pod labels/annotations 需操作员白名单，保留的内部前缀拒绝写入；网络策略 DNS 由 Supervisor 控制，无法验证描述符时拒绝代理请求。
- 升级风险： OCSF 文件名由 .log 改为 .jsonl；外部驱动 bootstrap 描述符、Go SDK 形参和 Kubernetes 标签规则均有兼容性变化。版本说明没有证明跨后端策略等价、毫秒级延迟或绕过不可行；需要故障注入和安全回归测试。

2. Paperclip v2026.1023.0：私有任务权限、Break-glass 审计和费用失败关闭

- 官方仓库： https://github.com/paperclipai/paperclip ；Release： https://github.com/paperclipai/paperclip/releases/tag/v2026.1023.0 ， 2026-10-24 00:03 UTC。GitHub REST 106,958 Stars / 17,765 Forks， MIT。此前已跟踪 v2026.1012.0 的 MCP 委派授权；本版是新权限模型，不是重复报道。
- 私有 Task/Project 按责任用户、创建者、当前 assignee、明确授权人和项目成员限定可见性；规则覆盖搜索、活动、运行记录、日志、附件与插件读取。管理员/Owner 默认也不能直接查看私有任务；?breakGlass=true 需产生审计记录和警示。
- Agent 的访问权限与本次运行负责人的权限取交集，降低复用 Agent 泄露其他人任务的风险。预算策略对未能可靠计价的用量默认 block，待审计账目调整后恢复；费用改为可回放的精确账本。
- 重要兼容提醒： Operator 预设权限由 1 项扩大为 14 项，现有 Operator 也会获得新增授权；应在升级前审查角色。官方还新增 BYO 模型网关、GitHub Review Check 与 Slack 自动配置，但本期主要价值在私密性和授权可追溯。权限交叉和 break-glass 的真实隔离尚需独立渗透验证。

3. OpenRig v0.7.0：人类可用性、部分恢复和干净的 Agent 启动环境

- 官方仓库： https://github.com/mvschwarz/openrig ；Release： https://github.com/mvschwarz/openrig/releases/tag/v0.7.0 ， 2026-10-23 14:12 UTC。GitHub REST 8,168 Stars / 665 Forks， Apache-2.0。此前 10 月 13 日 v0.6.x 已报道跨主机恢复与交付不确定性；本版进一步处理人类参与和局部故障。
- Human gateway 支持 quiet hours 与 asleep/out-of-office：普通请求等待恢复后逐条交付，紧急升级不被静默延迟；授权范围内可记录代理决定，但权限提示不会自动代人决定。
- 守护进程可在重启后恢复 kernel；一个 seat 缺少启动文件时其他 seat 仍可恢复。忙碌 daemon 会接收请求；写入超时则明确标记“ 结果未知 ”， 而非假装失败或成功。
- 破坏性变化： 新 Agent 不再默认继承 tmux 全局环境变量，减少凭据意外扩散，但依赖旧环境注入的部署需迁移；升级执行数据库迁移和托管 Skill/Plugin 文件更新。没有独立的恢复成功率或消息 exactly-once 测试。

4. Anthropic Sandbox Runtime v0.0.81：Windows 沙箱逃逸路径的具体修复（首次收录）

- 官方仓库： https://github.com/anthropics/sandbox-runtime ；Release： https://github.com/anthropics/sandbox-runtime/releases/tag/v0.0.81 ，2026-10-20 01:01 UTC。GitHub REST 6,466 Stars / 567 Forks，Apache-2.0。这是 2025 年已创建的项目，不是 10 月 25 日新建；本期因跨平台 OS 级 Agent 隔离的关键修复与近期关注而首次纳入。
- CLI/库可用系统级隔离限制任意进程及其子进程的文件和网络权限，macOS 用 Seatbelt、Linux 用 bubblewrap；Windows 使用专用账户、受限令牌和 Windows Filtering Platform。
- v0.0.81 全部改动仅针对 Windows：默认 write-restricted token，修复 AppContainer 子进程可能绕过网络拦截、stdin 管道端点可被子进程冒用，以及拒绝 ACL 过早恢复等问题；loopback 访问须安装时明确授权。升级 Windows 安装必须重新运行 setup。
- 风险边界： 为工具兼容而开放的用户配置目录可能包含 npm/pip/NuGet 等 token，且 Windows 单机共用 sandbox 账户；官方明确研究预览，未证明不存在其他逃逸途径。不可把 v0.0.81 误写成 macOS/Linux 的安全升级。

5. Cindy v0.1.115：跨 Harness 本地工作台的热度回升（首次收录）

- 官方仓库： https://github.com/makecindy/cindy ；Release： https://github.com/makecindy/cindy/releases/tag/v0.1.115 ， 2026-10-23 02:46 UTC。GitHub REST 4,084 Stars / 584 Forks，Apache-2.0。GitHub Trending 日榜观察到 471 stars today（滚动榜单口径）。
- Cindy 开源桌面/移动客户端以 Claude Code、Codex 为首批 Harness；官方描述支持跨模型/跨 Harness 任务、共享 Memory/Skills、浏览器/电脑/手机操作及日程/IM 自动化。v0.1.115 改进群聊中多个伙伴依次发言、引用/话题和任务近况展示。
- 开源范围必须分清： 仓库明确只包含客户端与共享包，后端服务在独立仓库且不属于本项目。Skip Sign-In 可使用部分本地 Agent，服务端能力不可用。不能将其称为 “ 完整开源的自托管 Agent 云平台 ” ，也不能把功能说明当作跨设备可靠性测试。

去重、未收录与验证建议

- VectifyAI/PageIndex v0.4.7 扩充本地/云端统一 SDK、对话协议和缓存连续性，但 10 月 17 日已报道 Flash 索引与统一工具契约，本次不重复作为核心新趋势。Orca v1.4.239 主要是工作区/手机/浏览器体验与恢复改进；Ruflo v3.62.0 新增只读 CUDA Launch Plan；OPAL v0.3.8 新增只读观察/比较命令，均暂不另立核心条目。
- Charonyuu/whatsmyagentdoing（本地 Coding Agent 活动可视化）和 PandaSI-Labs/pandasi-agent（特定链上代币的离线确定性证据检查）已查看官方 README，但暂不足以证明跨领域技术路线改变，不为凑数收录。
- 建议优先实测：① OpenShell 新后端 Sandbox Protocol 的策略一致性、Push 传播与失联退化；② Paperclip 私有任务在插件、日志和 break-glass 下的越权回归；③ OpenRig 人工 quiet-hours 下的审批和重复投递；④ Anthropic Windows sandbox 的进程树逃逸/配置文件暴露；⑤ Cindy 离线本地模式的能力边界。
- 官方 REST 精确观测、Release URL 与时间存于 data/snapshots/2026/10/2026-10-25.json；上述功能为官方一手材料描述，未进行独立性能或安全复现。